

Low-Level Protocol Exploitation and Physical-Layer Defenses for NFC Smart Lock Systems

NUS Computer Security Project Report

Xinjie Liu
Chu Kou Chen College, Zhejiang
University
Hangzhou, China
kawaiishinsuguru@gmail.com

Yulin Li
College of Computer Science and
Technology, Zhejiang University
Hangzhou, China
LeenSed@163.com

Chengfeier Pei
School of Integrated Circuits,
Shanghai Jiao Tong University
Shanghai, China
faye-official@sjtu.edu.cn

Canyu Liu
Chu Kou Chen College, Zhejiang
University
Hangzhou, China
liucanyu0411@gmail.com

Peize Yang
School of Integrated Circuits,
Shanghai Jiao Tong University
Shanghai, China
legacy1083@sjtu.edu.cn

Abstract

This paper presents a hardware-software integrated security evaluation and mitigation pipeline for near-field communication (NFC) smart lock systems. By utilizing commercial-off-the-shelf platforms, including the Proxmark3 RDV and HackRF One, we successfully demonstrate a non-contact, passive protocol sniffing and cloning replay attack against a MIFARE Ultralight EV1 smart card system without prior lock interaction. Furthermore, to address the vulnerability of static data leakage in the RF field, we propose and implement a two-tier defense mechanism...

Keywords

NFC Security, Protocol Sniffing, Replay Attack, Active Jamming, Hardware Defense

1 Introduction

Near-Field Communication (NFC) operating at 13.56 MHz has been widely adopted in modern physical access control systems, including campus dormitories and residential smart locks. While higher-layer protocols often assume a secure physical boundary, the open nature of the RF air interface poses severe security threats...

Our team addresses this problem via a 21-day hardware-software co-design. Leveraging the synergy between Computer Science (CS) and Electrical Engineering (EE) skillsets, we build a high-fidelity mock door lock, exploit its low-level protocol logic, and deploy an physical-layer defense grid.

2 Experimental Sandbox Setup

To bypass the overhead of custom PCB design, our implementation leverages existing high-precision platforms provided for this project.

2.1 Hardware Provisioning

The hardware sandbox consists of:

- **Proxmark3 RDV (Elechouse):** Equipped with a 13.56 MHz high-frequency antenna (HF_ANT) for protocol sniffing and card emulation. The legacy AT91SAM7S microcontroller firmware is stripped and optimized.
- **HackRF One (SDR):** Utilized for raw I/Q signal capturing and active RF jamming transmission.
- **Target Tags:** NXP MIFARE Ultralight EV1 contactless tags and backdoor-enabled Gen1a Magic Cards.

2.2 Target Mock Lock Construction

We constructed a standalone target mock lock using an MCU connected to a PN532 RF frontend. The initial vulnerable firmware (**Lock V1.0**) strictly validates the 7-byte static Unique Identifier (UID) of the MIFARE Ultralight EV1 tag to trigger the unlocking GPIO state.

3 Vulnerability Exploitation (Red Team)

Our attack model requires zero prior interaction with the target lock frontend. The attack pipeline contains two distinct phases: sniffing and cloning.

3.1 Passive RF Sniffing

The Proxmark3 RDV is hidden near the target reader operating in non-contact sniffing mode.

```
1 # Activate 14443A passive sniffing
2 hf 14443a sniff
3 # Dump and trace captured frames
4 hf list 14443a
```

Listing 1: Proxmark3 Protocol Sniffing Execution

When a legitimate user interacts with the lock, the 13.56 MHz carrier's ASK modulation and the tag's backscattered load modulation are recorded. The extracted raw frame trace reveals the 7-byte static UID: 04 AA 11 B2 3C 4D 5E.

3.2 Tag Emulation and Cloning

Using the identified backdoor-enabled Magic Cards sorted during our diagnostic phase, we mutate the Gen1a card's Sector 0 block to match the intercepted identity:

```
1 hf mf csetuid -u 04AA11B23C4D5E
```

The cloned shadow card successfully achieves complete physical bypass on Lock V1.0.

4 Physical-Layer Analysis (EE Domain)

The EE members analyzed the captured I/Q waveform via MATLAB. In the time-domain wave, the Frame Delay Time (FDT) between the reader's final EMD block and the tag's Response Start Time is precisely measured as:

$$FDT = (n \times 128) + 84 \quad \text{carrier cycles}$$

This boundary serves as the critical timing characteristic for detecting proxy hardware relays, as software-based network routing introduces propagation delays significantly exceeding this threshold.

5 Proposed Defensive Mechanism (Blue Team)

To mitigate static identity leakage, we upgrade the infrastructure to **Lock V2.0** using two defensive layers.

5.1 Protocol Hardening: Dynamic Challenge

We eliminate static validation by implementing a rolling cryptographic challenge-response sequence using the 32-bit password auth vector of the Ultralight EV1 tag.

5.2 Active RF Defensive Grid via HackRF

We deploy a reactive physical shield utilizing the HackRF One integrated with GNU Radio. As shown in Table ??, the system dynamically tracks energy deviations in the 13.56 MHz spectrum.

Table 1: Defensive Signal Threshold Matrix

Metric Parameter	Threshold Boundary	System Action
Normal RSSI Variance	$< \pm 2.1 \text{ dB}$	Allow Transmission
Sniffer Proximity Probing	$\geq +4.5 \text{ dB}$	Alert / Lock State
Relay Delay Deviation	$> 12 \mu\text{s}$	Trigger Jamming

Upon identifying an unauthorized proxy node or anomalous load-modulation depth (indicating a nearby sniffer like the Proxmark3), the HackRF immediately fires a targeted 13.56 MHz white-noise burst. This collapses the RF synchronization loop, forcing the rogue collector into a Missing Sync error state and rendering the attack obsolete.

6 Conclusion

This project successfully demonstrates the severe security risks associated with static credential exposure over the NFC interface and provides an academic proof-of-concept for dynamic physical-layer defense.

References

- [1] RfidResearchGroup. (2026). *The Proxmark3 Open-Source Firmware Ecosystem*. GitHub Repository.
- [2] ISO/IEC 14443. *Identification cards – Contactless integrated circuit cards – Proximity cards*.

Temporary page!

L^AT_EX was unable to guess the total number of pages correctly. As there was some unprocessed data that should have been added to the final page this extra page has been added to receive it.

If you rerun the document (without altering it) this surplus page will go away, because L^AT_EX now knows how many pages to expect for this document.